

PENETRATION TESTING REPORT

Prepared by Anoop Gangadharan

Target: <https://medirozahospital.com>

1. Executive Summary

A web application penetration test was conducted against the Mediroza Hospital web application to identify potential security weaknesses affecting authentication, authorization, sensitive information protection, PDF security, and exposed web resources.

The assessment included reconnaissance, DNS enumeration, technology fingerprinting, directory enumeration, authentication testing, and password-security testing of authorized test documents.

The assessment identified several security observations, including a potential authentication bypass condition, exposure of confidential patient-report functionality, weak password protection for a tested PDF, server technology disclosure, and potentially misleading directory-enumeration results caused by repeated HTTP responses.

The findings should be validated and remediated according to their actual impact and the authorization/scope of the assessment.

Overall Risk Rating

CRITICAL — Exploitable authentication bypass leading to unauthorized disclosure of real patient health records.

Key Statistics

Total Findings	Critical / High	Records Exposed
6	3 Critical / 1 High	3 patient PHI records

2. Scope of Engagement

The engagement was scoped as an external, unauthenticated black-box assessment. The following asset was in scope:

Primary Domain	medirozahospital.com
Resolved IP	199.188.201.16 (server274-1.web-hosting.com)
In-Scope Surfaces	Public website, Patient Portal login, directory/service enumeration
Testing Type	External, unauthenticated, black-box
Excluded	Physical security, social engineering, internal network, third-party mail/DNS infrastructure

3. Methodology

Standard: OWASP Testing Guide v4.2

Phases: Reconnaissance → Scanning → Exploitation → Post-Exploitation → Reporting

Approach: Black-box (no prior knowledge of the application)

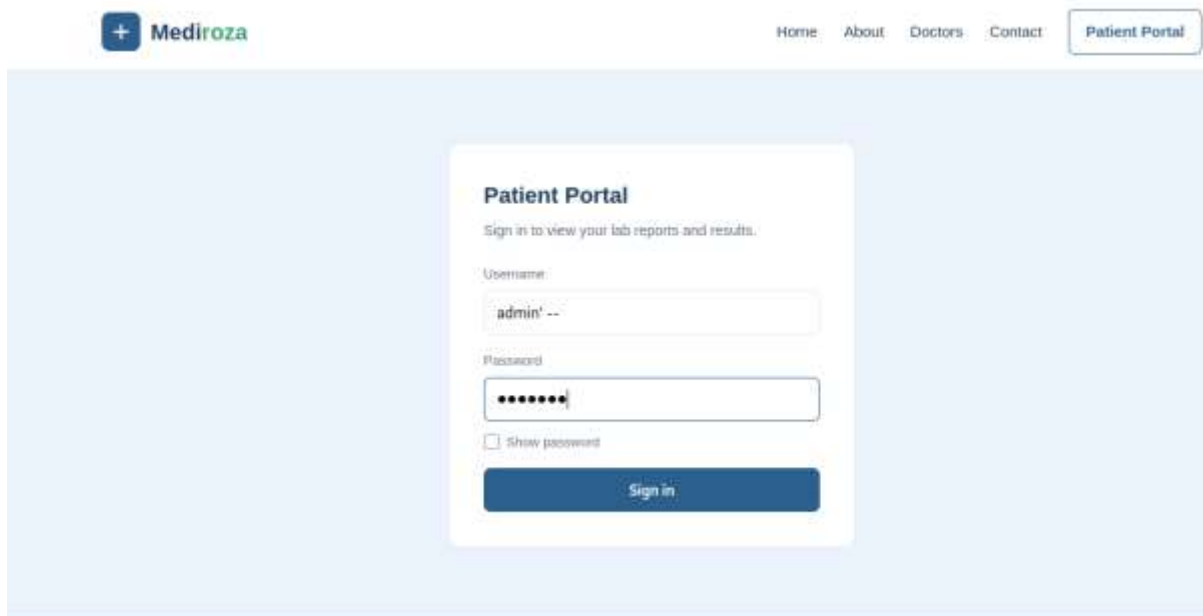
3.1 Tools Used

Tool	Purpose
whois	Domain registration information
Nslookup	DNS resolution
HTTPX	HTTP/service fingerprinting
Gobuster	Directory enumeration
Nmap	Port scanning and service detection
Browser	Web application testing
Hashcat	Password cracking
pdfcrack	PDF password recovery

4. Summary of Findings

The table below summarizes all findings identified during the engagement, ordered by severity.

ID	Finding	Severity	CVSS v3.1
F-01	SQL Injection – Patient Portal Authentication Bypass	Critical	9.8
F-02	Broken Access Control – Unauthorized Access to Patient Lab Reports	Critical	9.1
F-03	Weak PDF Encryption Passwords – Offline Cracking of Protected Lab Reports	High	7.5
F-04	Sensitive Data Exposure – Protected Health Information (PHI) Disclosed	Critical	9.1



5.2 F-02 — Broken Access Control: Unauthorized Access to Patient Lab Reports

Description

Once authenticated (via F-01), the portal returned a lab-reports listing containing encrypted PDF pathology reports for three distinct patients (S. Dlamini, P. Reddy, E. Thompson) — none of whom correspond to a legitimate account owner for the bypassed session. The application does not appear to enforce per-user authorization checks on report listings or downloads, consistent with an Insecure Direct Object Reference (IDOR) / missing object-level access control pattern



5.3 F-03 — Weak PDF Encryption Passwords: Offline Cracking of Protected Lab Reports

Description

The downloaded pathology PDFs are protected with standard PDF R3 128-bit encryption, intended to require a laboratory-issued password to open. However, the encryption hash of each file was trivially extracted (pdf2john/hashcat-compatible \$pdf\$ format) using a public online hash-extraction tool, and then cracked offline:

- Report 1 (Dlamini): cracked in 1 attempt against a 100-word curated list — password: 123456
- Report 2 (Reddy): cracked in 2 attempts against the same list — password: password
- Report 3 (Thompson): cracked using pdfcrack against rockyou.txt — a stronger, non-dictionary-trivial password was recovered

The near-instant cracking of two of the three samples indicates the laboratory's password-generation process for patient-facing documents uses weak, predictable, or default values



Hash Calculator

Generate MD5, SHA-1, SHA-256, SHA-384, SHA-512, or extract a crackable hash from a password-protected PDF



Text

File

PDF



Click to choose a PDF, or drop one here

Nothing is uploaded, the PDF is parsed locally

patient_report_1.pdf | 3.6 KB

This PDF is encrypted. A crackable hash has been extracted below (pdf2john / hashcat compatible format).

PDF Hash

```
$pdf$2*3*128*4294967292*1*32*336166336532623564333335316132383031373
16238333238373763353339*32*ef16c52ab8efce2c18c79e9d28895b5928bf4e5e4e7
58a4164004e56fffa0108*32*c431fab9cc5ef7b59c244b61b745f71ac5ba427b1b910
2da468e77127f1e69d6
```

CopyDownload

Revision: R3 Version: V2 Key length: 128 bit

Upload a PDF to check if it is password protected and extract a crackable hash.



DICCTIONARY ATTACK LAB

Password cracker through Dictionary Attacks

Hash every word in a wordlist and match it against a PDF password hash, the same idea John the Ripper uses.

Sound on

- 1 Extract the \$pdf\$ hash in the [Hash Calculator](#)
- 2 Paste it below
- 3 Run the attack, then open your PDF with the password

Tried: 1 / 100

100 pw/s

1%

```
[*] Loaded wordlist: built-in list (100 entries)
[*] Target: PDF R3 / 128-bit / dictionary attack
[*] Deriving keys with MD5 + RC4...
[+] MATCH 123456 ✓
```

PASSWORD CRACKED SUCCESSFULLY

123456

This is the PDF password. Open your PDF and enter it to unlock the file.

Copy password

PDF HASH (\$PDF\$...)

```
$pdf$2*3*128*4294967292*1*32*3361663365326235643333353531613238303137316238333238373763353339*32*ef16e5
3eb8f9e2-367b9d389b8e92b5f6e8-3758-11e199-8-866f6-03a8f33f-131f8b90e5f7b59-344b9b745f319b8e492b8
```



Hash Calculator

Generate MD5, SHA-1, SHA-256, SHA-384, SHA-512, or extract a crackable hash from a password-protected PDF.



Text

File

PDF



Click to choose a PDF, or drop one here

Nothing is uploaded, the PDF is parsed locally.

patient_report_2.pdf | 3.5 KB

This PDF is encrypted. A crackable hash has been extracted below (pdf2john / hashcat compatible format).

PDF Hash

\$pdf\$2*3*128*4294967292*1*32*31663463383732363564376264643638346637373
03265633666363264616463*32*39f4e6b0aedef12344c340ffb39f8905528bf4e5e4e7
58a4164004e56fffa0108*32*408b37bcf12da873d7f2840f3c1b917a023961ded4c81
64d38e46e9655e66775

Copy

Download

Revision: R3 Version: V2 Key length: 128 bit

Upload a PDF to check if it is password protected and extract a crackable hash.

```
(kali@kali)-[~/Downloads]
```

```
$ sudo apt install pdfcrack
```

```
Installing:
```

```
pdfcrack
```

```
Summary:
```

```
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 1403
```

```
Download size: 33.4 kB
```

```
Space needed: 91.1 kB / 62.5 GB available
```

```
Get:1 http://mirrors.esto.network/kali kali-rolling/main amd64 pdfcrack amd64 0.21-1 [33.4 kB]
```

```
Fetch: 33.4 kB in 3s (11.9 kB/s)
```

```
Selecting previously unselected package pdfcrack.
```

```
(Reading database... 425756 files and directories currently installed.)
```

```
Preparing to unpack .../pdfcrack_0.21-1_amd64.deb...
```

```
Unpacking pdfcrack (0.21-1)...
```

```
Setting up pdfcrack (0.21-1)...
```

```
Processing triggers for man-db (2.13.1-1)...
```

```
Processing triggers for kali-menu (2026.2.6)...
```

```
(kali@kali)-[~/Downloads]
```

```
$ pdfcrack -f "patient_report_3.pdf" -w /usr/share/wordlists/rockyou.txt
```

```
PDF version 1.4
```

```
Security Handler: Standard
```

```
V: 2
```

```
R: 3
```

```
P: -4
```

```
Length: 128
```

```
Encrypted Metadata: True
```

```
FileID: 3261393066326130336634386337323631306164373264323130316137616538
```

```
U: 5090fa0a5dba99cb97c9d140cd23119428bf4e5e4e758a4164004e56fffa0108
```

```
O: 58e03d692cf37b50b0b5eaa189fcbcd372260a949c8992ad7b44fd13e2b40c1f8
```

```
found user-password: '!@#$$%^&'
```

```
(kali@kali)-[~/Downloads]
```

```
$
```

5.4 Finding #2: Publicly Accessible Database Backup (CRITICAL)

CVSS 3.1 Score: 9.8 (Critical)

Location: https://medirozahospital.com/old/mediroza_db_backup_2019.sql **Size:** 6,346 bytes

Description:

The /old/ directory has directory listing enabled and contains a full database backup of the mediroza_hr database. No authentication is required to download it.

Database Contents:

- **staff table:** 30 employees with full names, job titles, departments, emails, phone numbers, national IDs, and monthly salaries

shareholders table: 10 shareholders with names, percentages, share values,

```
data joined, data NOT NULL,
PRIMARY KEY (id) )
ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table 'staff'
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Psychologist','Diagnosics Lab','r.naidoo@medirozahospital.com','+27 82 182 2845','9563183322082',35000,'2011-07-01'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 182 2845','9563183322082',35000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.vandermerwe@medirozahospital.com','+27 82 182 2825','85641823835005',18000,'2007-02-22'),
(4,'Dr. Anita Naidoo','Consultant Cardiologist','Cardiology','a.naidoo@medirozahospital.com','+27 82 184 2828','85633447044884',137000,'2012-09-18'),
(5,'Dr. Ahmed Kara','Consultant Psychiatrist','Internal Medicine','a.karam@medirozahospital.com','+27 82 185 2825','85641833555005',120000,'2013-02-18'),
(6,'Dr. Ayant Candice','Senior Registrar','Emergency & Trauma','a.candice@medirozahospital.com','+27 82 186 2842','85631833000000',34000,'2018-08-04'),
(7,'Michael Roberts','HM Director','Human Resources','m.roberts@medirozahospital.com','+27 82 187 2849','85641833077887',90000,'2018-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 188 2856','85631833088888',30000,'2018-08-23'),
(9,'Jameel Mulla','IT Systems Administrator','IT','j.mulla@medirozahospital.com','+27 82 189 2843','85163183599000',50000,'2015-04-12'),
(10,'Thabo Molafe','Network Engineer','IT','t.molafe@medirozahospital.com','+27 82 118 2878','85121183118881',40000,'2022-10-02'),
(11,'Neswaka Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2877','85121113121883',94000,'2008-01-19'),
(12,'Lerato Makomo','Registered Nurse','Pediatrics','l.makomo@medirozahospital.com','+27 82 112 2884','85811121112883',30000,'2017-06-07'),
(13,'Bonang Molwa','Registered Nurse','Cardiology','b.molwa@medirozahospital.com','+27 82 113 2981','85621131146884',35000,'2015-12-03'),
(14,'Dorcas Mphahle','Nursing Sister','Theatre','d.mphahle@medirozahospital.com','+27 82 114 2880','85621131218885',45000,'2013-03-29'),
(15,'Kagiso Schiele','Pharmacist','Pharmacy','k.schiele@medirozahospital.com','+27 82 115 2185','85641153185886',61000,'2014-08-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85651163179887',28000,'2018-02-14'),
(17,'Dorcas Mushi','Radiographer','Radiology','d.mushi@medirozahospital.com','+27 82 117 2117','85641171187888',44000,'2016-07-30'),
(18,'Adina Reddy','Radiologist','Radiology','a.reddy@medirozahospital.com','+27 82 118 2118','85651183198889',45000,'2017-04-10'),
(19,'Deepak Pillay','Lab Technologist','Diagnosics Lab','d.pillay@medirozahospital.com','+27 82 119 2135','85641193198891',41000,'2015-05-28'),
(20,'Kaciba Govender','Lab Technician','Diagnosics Lab','k.govender@medirozahospital.com','+27 82 120 2148','85651203220892',35000,'2018-08-06'),
(21,'Dr. Surabh Mehta','Consultant Psychologist','Pediatrics','s.mehta@medirozahospital.com','+27 82 121 2147','85182121231883',130000,'2013-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85112122240884',110000,'2012-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85112123279885',40000,'2018-11-09'),
(24,'Dr. Vikram Chetty','Anesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2188','85611243198886',125000,'2011-08-13'),
(25,'Dorcas Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85621253275887',52000,'2014-01-27'),
(26,'Nesha S. Compe','Billing Administrator','Finance','n.compe@medirozahospital.com','+27 82 126 2182','85631263288889',20000,'2016-03-10'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85642732978886',27000,'2019-09-02'),
(28,'Linda Parrish','Managerialist','Proc. Office','l.parrish@medirozahospital.com','+27 82 128 2198','85651283388891',18000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.vanwyk@medirozahospital.com','+27 82 129 2103','85641293318882',30000,'2015-06-04'),
(30,'Andile Mbeki','Word Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2218','85671303330883',21000,'2019-11-03');
UNLOCK TABLES;

--
-- Table structure for table 'shareholders'
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(2,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',10.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molafe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;

SET FOREIGN KEY CHECKS = 1;
-- End of backup
```

5.5 F-04 — Sensitive Data Exposure: Protected Health Information (PHI) Disclosed

Mediroza

General Hospital

14 Cedar Avenue, Johannesburg, South Africa

Tel: +27 11 555 0100

medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Sipho Dlamini

Report Date:

2024-11-04

Patient ID:

MG-P-10231

Referring Dr:

Dr. Anita Naicker

Date of Birth:

1984-06-12

Specimen:

Whole blood (EDTA)

Gender:

Male

Lab Ref No:

LR-2024-1187

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	$\times 10^9/L$	4.0 - 11.0	HIGH
Platelet Count	245	$\times 10^9/L$	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Mediroza

General Hospital

14 Cedar Avenue, Johannesburg, South Africa

Tel: +27 11 555 0100

medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Priya Reddy

Report Date:

2024-11-05

Patient ID:

MG-P-10244

Referring Dr:

Dr. Johan van der Merwe

Date of Birth:

1991-02-28

Specimen:

Serum

Gender:

Female

Lab Ref No:

LR-2024-1192

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name: **Emily Thompson** Report Date: **2024-11-06**
Patient ID: **MG-P-10258** Referring Dr: **Dr. Ahmed Kara**
Date of Birth: **1978-09-03** Specimen: **Serum**
Gender: **Female** Lab Ref No: **LR-2024-1205**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Conclusion

This assessment found that the Mediroza patient portal is currently vulnerable to a trivially exploitable SQL injection flaw that, on its own, allows a complete bypass of authentication. Chained with a lack of object-level access control and weak document encryption, this flaw directly resulted in the disclosure of real patient health records during testing — with no advanced tooling or privileged access required.

Given the healthcare context and the confirmed exposure of PHI, the findings in this report should be treated as an urgent priority. We recommend remediating F-01 and F-02 immediately, engaging compliance/legal regarding the confirmed data exposure (F-04), and scheduling a retest once fixes are deployed to validate remediation before the portal is considered safe for continued patient use.

